SECURITY INCIDENT REPORT

RDP Brute Force Attack / Windows Event Log Analysis

Field	Details
Log File	RDP-Security.evtx
Attack Type	Botnet-Assisted RDP Brute Force
Target Account	Administrator
Total Failed Events	1,567 (Event ID 4625)
Breach Confirmed	Event ID 4624 (Successful Logon)
Breach Timestamp	5/20/2025 at 09:51:45 AM
Attacker IP Address	203.205.34.107
Compromised Workstation	DESKTOP-QNBC4UU
Attack Duration	About 41 minutes and 44 seconds
Post-Compromise Action	Password changed by attacker

---

1. Incident Overview

In this challenge, I identified a sustained brute force campaign targeting the local Administrator account via the Remote Desktop Protocol (RDP). The attack originated from multiple source IP addresses, which is characteristic of a botnet-coordinated operation rather than a single manual threat actor. Analysis was conducted using the saved Windows Security Event Log file RDP-Security.evtx, loaded into Windows Event Viewer for examination.

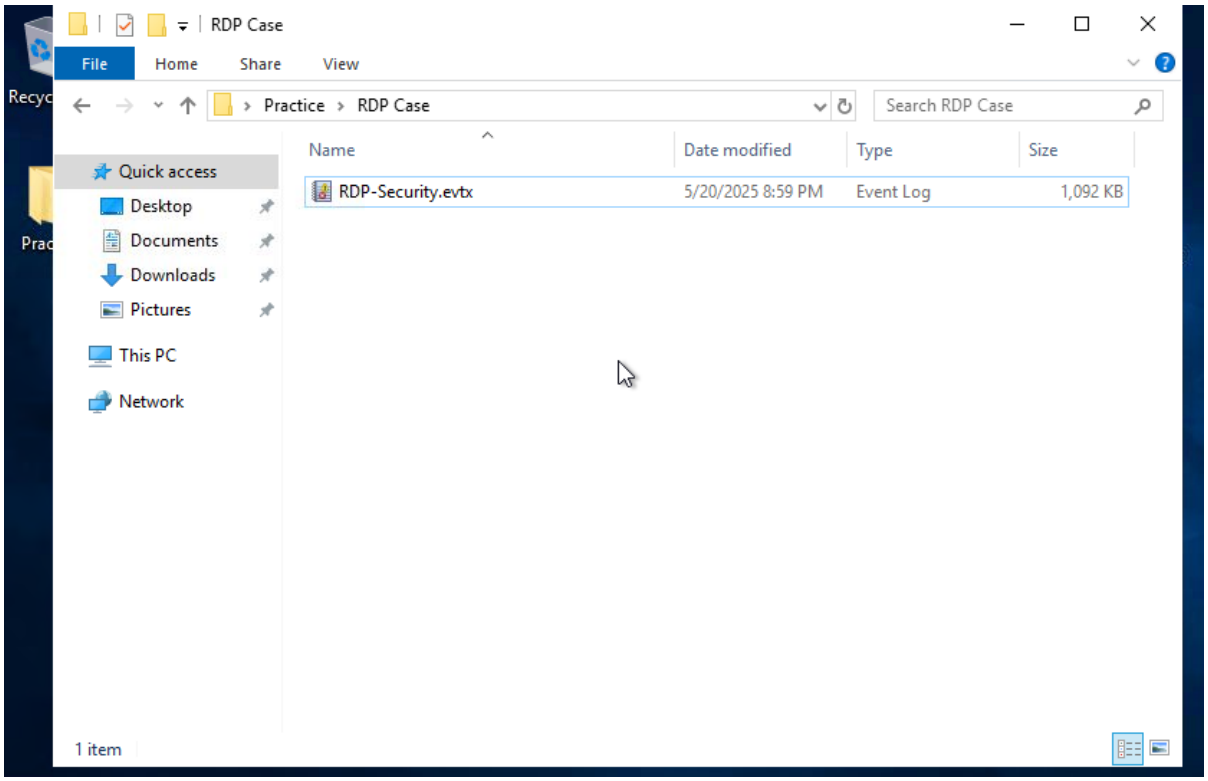

Figure 1: RDP Case folder containing the RDP-Security.evtx event log file

2. Initial Findings

A total of 1,567 events were recorded under Event ID 4625 (An account failed to log on). This volume of failed authentication attempts, originating from multiple distinct IP addresses, strongly indicates an automated and distributed brute force attack. Since Windows logs Event ID 4625 after 3 consecutive failed login attempts, the actual number of attempted passwords was estimated to be 1567 attempts.

The attacker's objective was clearly to gain unauthorized access to the Administrator account, which holds the highest privilege level on this Windows system.

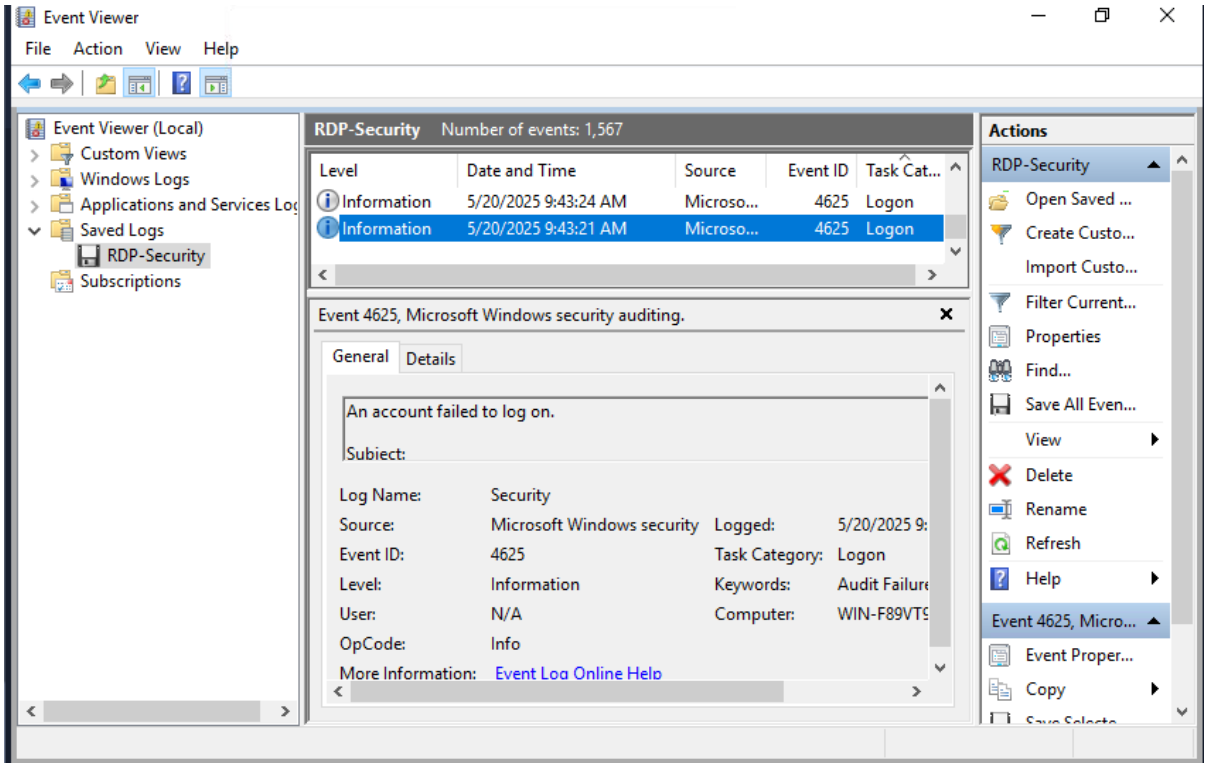

Figure 2: Event ID 4625 (failed logon) entries in the RDP-Security log

3. Breach Confirmation

To determine whether any of the authentication attempts succeeded, the event log was filtered for Event ID 4624 (An account was successfully logged on). The search function was used to filter for the keyword “success” to quickly identify any matching entries.

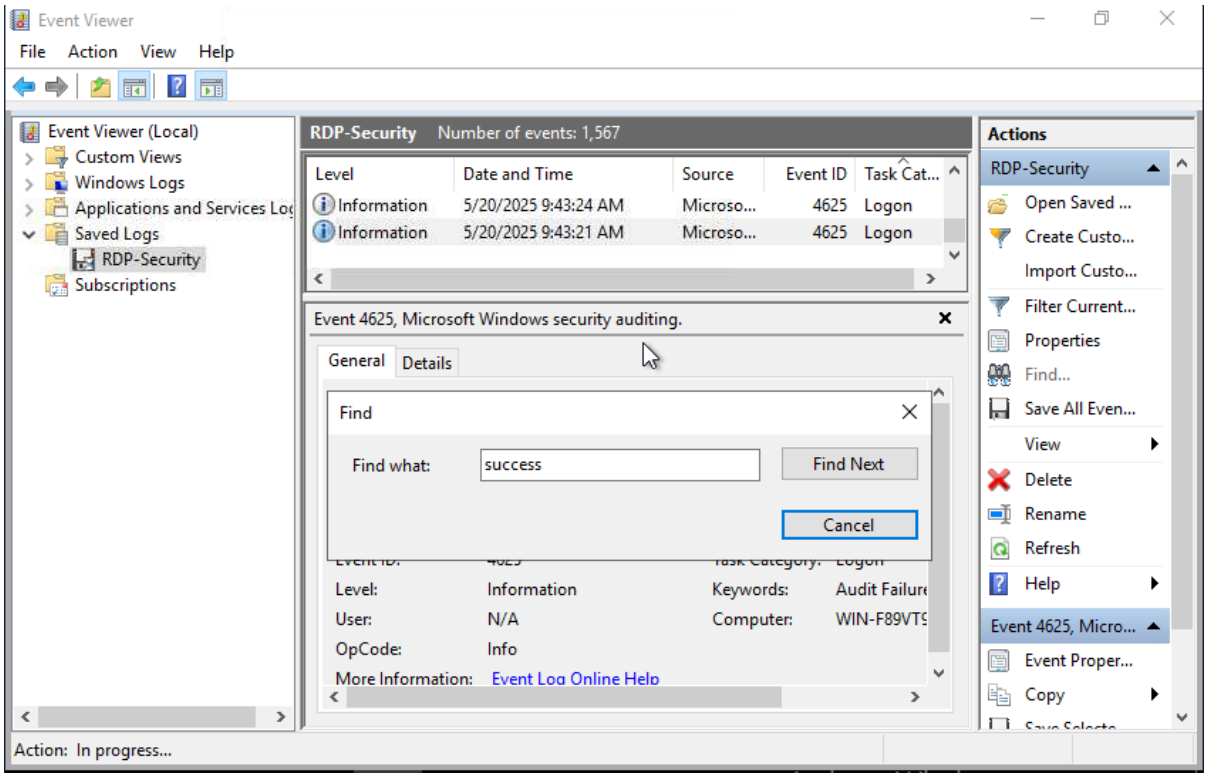

Figure 3: Using the Find function to search for successful logon events

A matching entry was found, confirming that the attacker ultimately broke through and gained access to the system. The successful logon event (Event ID 4624) identified the source IP and workstation involved.

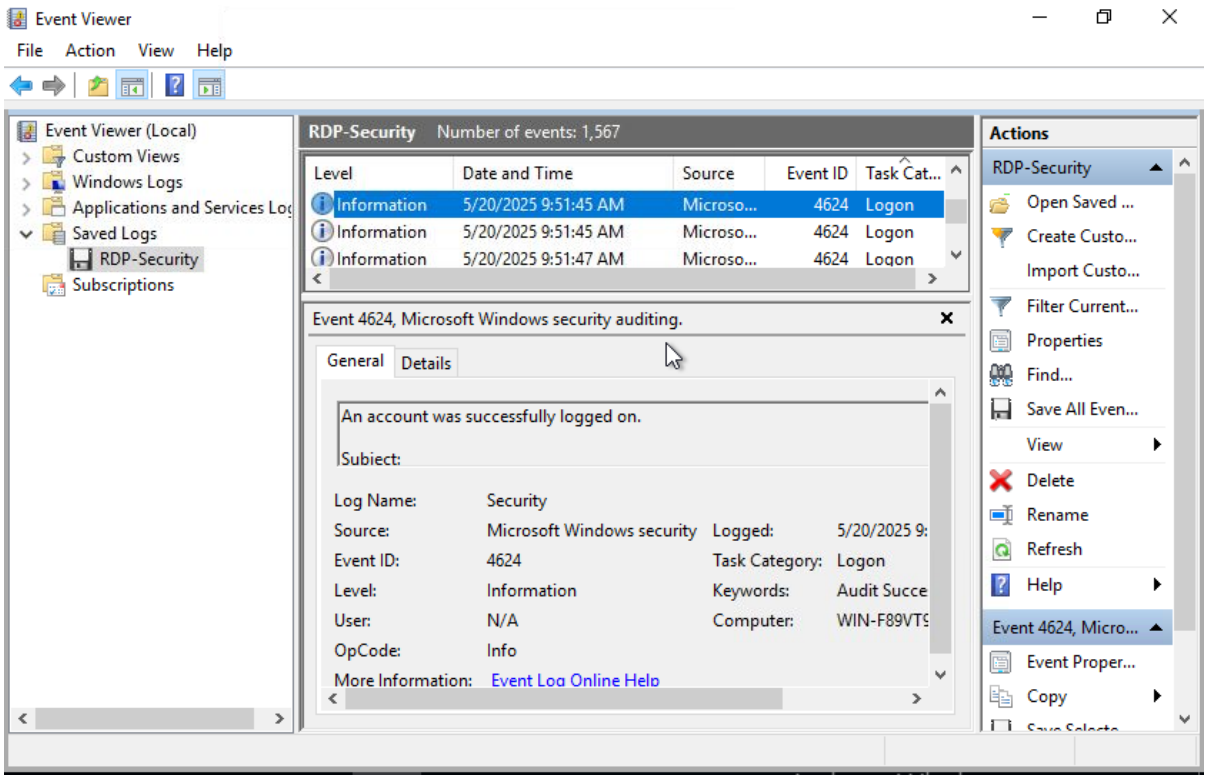

Figure 4: Event ID 4624 confirming a successful logon at 09:51:45 AM from IP 203.205.34.107

Event ID: 4624 — Successful Logon
Timestamp: 5/20/2025 at 09:51:45 AM
Source IP Address: 203.205.34.107
Workstation Name: DESKTOP-QNBC4UU
Logon Type: Network (RDP)

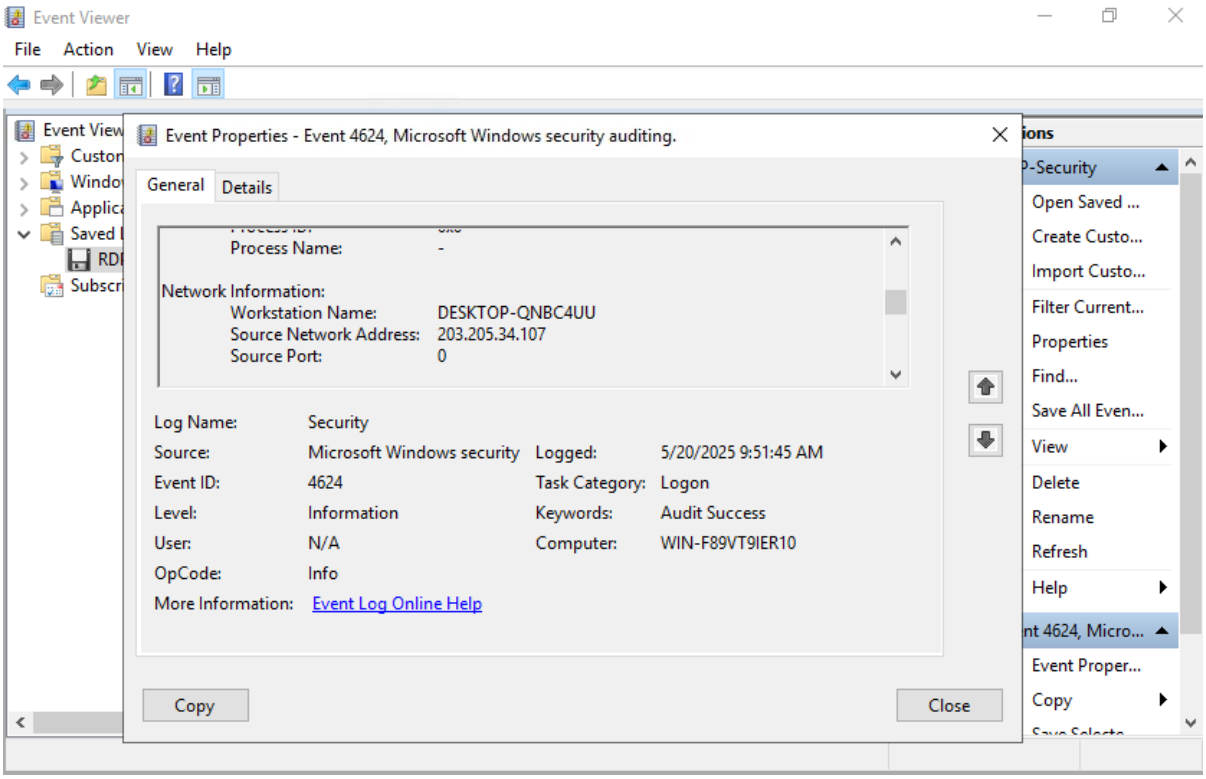

Figure 5: Network details: Workstation DESKTOP-QNBC4UU, Source IP 203.205.34.107

Immediately following the successful login, the attacker changed the account password, a deliberate tactic to lock out legitimate users and establish persistent access. The total window from the first observed failed attempt to the confirmed breach spanned approximately 41 minutes and 44 seconds.

4. Attack Characteristics

Based on the evidence gathered from the event logs, the following behavioral indicators were identified:

- Multiple source IP addresses were used, consistent with a botnet or distributed attack infrastructure rather than a single actor.
- The attack exclusively targeted the built-in Administrator account, suggesting either prior reconnaissance or opportunistic targeting of a commonly misconfigured default account.
- The high velocity of failed attempts is characteristic of automated credential stuffing or dictionary attack tooling.
- The immediate password change following successful access is a known persistence technique used to maintain exclusivity and prevent legitimate user recovery.

5. Containment & Immediate Response

The following actions should be treated as critical priority and executed without delay:

- Isolate the compromised machine (DESKTOP-QNBC4UU) from the network immediately to prevent lateral movement, data exfiltration, or further attacker activity.
- Reset all local and domain-level account passwords, starting with all privileged accounts including the Administrator.
- Block the attacker's known IP address (203.205.34.107) at the perimeter firewall. Review all Event ID 4625 source IPs and expand the block list accordingly.
- Conduct a full log review across all available sources — Security, System, Application, and PowerShell — to identify any post-compromise activity, persistence mechanisms, or lateral movement.
- Perform a comprehensive malware and forensic analysis of the affected system to detect implants, backdoors, unauthorized scheduled tasks, or modified registry entries.
- Escalate this incident to senior security personnel and management to assess any legal, regulatory, or customer notification obligations.

---

6. Root Cause & Preventive Recommendations

This breach was a direct result of a weak or easily guessable password on a high-privilege account exposed directly to the internet via RDP. The following hardening measures would have prevented or significantly delayed this attack:

6.1 Strong Password Policy

- Enforce a minimum password length of 15 characters, combining uppercase, lowercase, digits, and special characters.
- Implement regular password rotation for privileged accounts (every 90 days at minimum).
- Block dictionary words, usernames, and previously used passwords via password filters.

6.2 Multi-Factor Authentication (MFA)

- Enable MFA for all RDP and remote access sessions. Even with valid credentials, MFA would have prevented unauthorized access.

6.3 Account Lockout Policy

- Set an account lockout threshold of no more than 5 failed attempts within a 5-minute window.
- Configure a minimum lockout duration of 30 minutes, or require manual admin intervention for highly sensitive accounts.

6.4 Network & Firewall Controls

- Restrict RDP access (TCP port 3389) to known, authorized IP ranges only. Never expose RDP directly to the public internet.
- Require all RDP sessions to be tunneled through a VPN or an RDP Gateway solution.
- Deploy a Network Intrusion Detection/Prevention System (IDS/IPS) capable of detecting and automatically blocking brute force patterns in real time.

6.5 Monitoring & Alerting

- Configure SIEM rules to alert on any account generating more than 5 Event ID 4625 entries within a short rolling time window.
- Set up automated alerts for Event ID 4624 logons occurring outside of business hours or from unexpected geographic locations.

---

7. Conclusion

This incident demonstrates the serious risk of exposing RDP to the internet without strong authentication controls. The attacker was able to brute-force access to the Administrator account in under 42 minutes, after which they modified the account password to maintain exclusive access. Prompt detection and isolation are critical next steps.

The preventive controls outlined in Section 6 must be implemented as a matter of urgency. This incident should also serve as a trigger for a broader security review of all externally facing services, RDP configurations, and privileged account management practices across the organization.